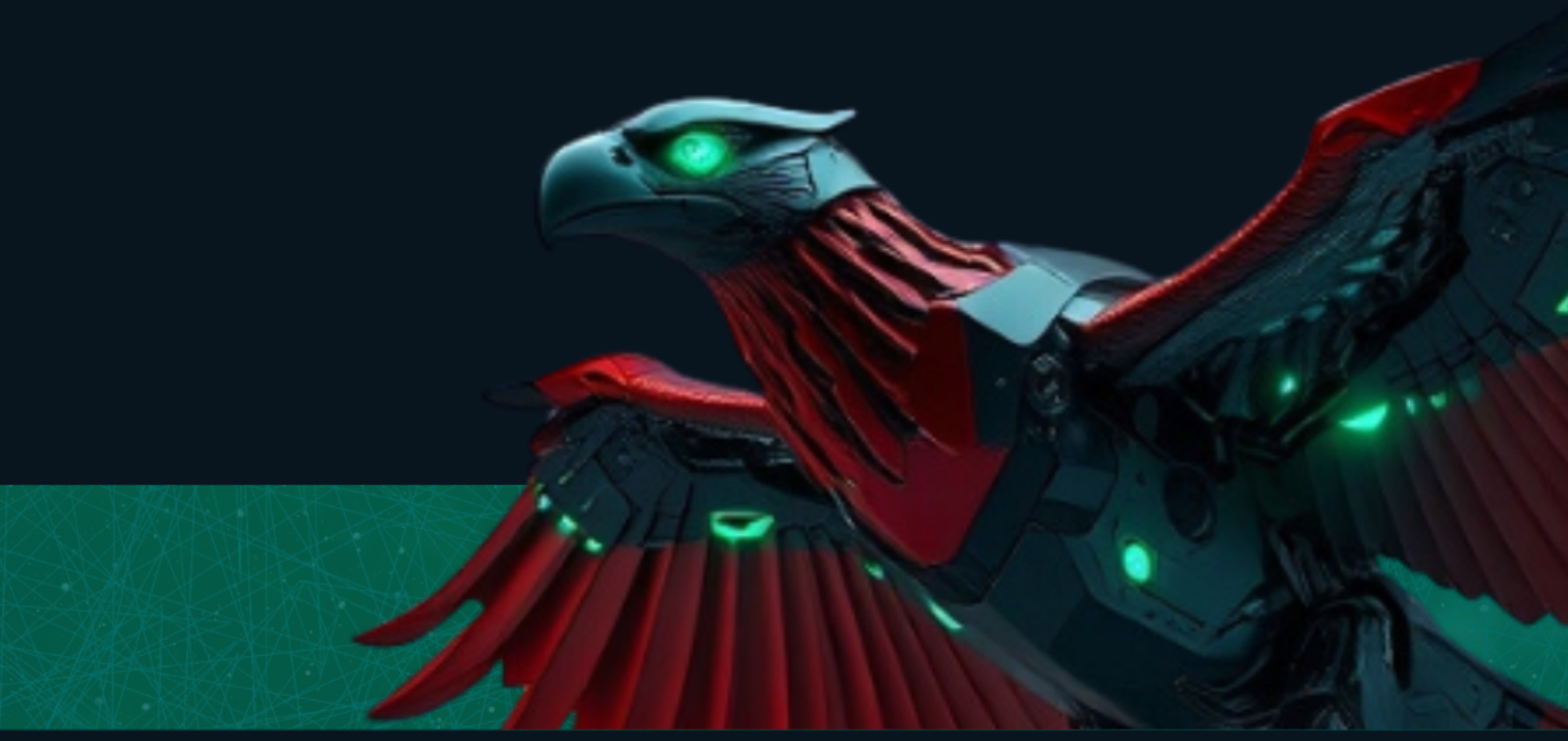
SOCBYTE
ALL BYTES SECURED

INTEL REPORT



Report Details

Title	Threat Advisory Report | CVE 2026-41679
Sub Title	Maximum-severity critical authorization bypass vulnerability affecting Paperclip
Status	Closed
Type	Advisory
Severity	High
Source	TheHackerNews.com
Created At	Aug 05, 2026, 07:49 PM

Threat Advisory Report | CVE 2026-41679

Maximum-severity critical authorization bypass vulnerability affecting Paperclip

Type: ADVISORY • Source: TheHackerNews.com • Created At: Aug 05, 2026, 07:49 PM

Analysis Summary

CVE-2026-41679 is a critical authorization bypass vulnerability affecting Paperclip, an open-source control plane for managing teams of AI agents. The flaw was discovered by security researchers at Oasis Security and publicly disclosed on August 4, 2026. In affected network-accessible deployments using default registration settings, the vulnerability allows an unauthenticated external attacker to self-register an account, approve their own command-line interface challenge to gain persistent board-level permissions, and misuse the company import endpoint to upload malicious .paperclip.yaml configurations.

When exploited, an attacker uses this elevated access to define an AI agent configured with Paperclip's built-in process adapter. Upon activating or waking the agent, the server executes arbitrary OS host commands as a child process under the operating-system privileges of the Paperclip service. While security research firms such as Rapid7 have published proof-of-concept Metasploit modules automating the attack chain, no active exploitation in the wild has been officially confirmed as of August 2026.

This vulnerability poses a severe threat to infrastructure, enabling complete server compromise and remote code execution (RCE). Successful exploitation grants attackers access to application data, source code repositories, API keys, credentials, and internal network services reachable from the host machine. To eliminate this risk, infrastructure teams operating Paperclip deployments should immediately upgrade to v2026.416.0 or later, which enforces proper instance-administrator checks on company imports and restricts default registration exposure.

Affected Product

- paperclip / paperclipai: All versions prior to v2026.416.0
- Specifically impacts network-accessible Paperclip deployments running in authenticated mode with the default open-registration configuration enabled.

Impact

- Complete System & Infrastructure Compromise: Attackers gain full control over the underlying host operating system with the privileges of the Paperclip service process, enabling them to execute arbitrary system commands, pivot deeper into internal network segments, or establish persistent backdoors.
- Mass Data Exfiltration & Intellectual Property Theft: Direct access to the server environment allows malicious actors to steal proprietary source code repositories, agent configurations, training datasets, and sensitive customer or corporate data stored on or accessible by the system.
- Credential & Secret Exposure: Attackers can extract locally stored credentials, API keys, database connection strings, and environment variables, compromising linked third-party services, LLM providers, and cloud infrastructure.
- Operational Disruption & Supply Chain Vulnerabilities: Compromised AI agents can be manipulated to push rogue code, issue malicious API commands, or disrupt automated business logic, halting daily operations and spreading malware across integrated developer pipelines or client systems.
- Severe Financial & Regulatory Consequences: Unintended data breaches caused by this vulnerability expose organizations to heavy regulatory fines, incident response costs, potential ransomware threats, and lasting damage to brand reputation and customer trust.

Vulnerabilities (CVEs)

CVE Number	Description	Published	CVSS Score
CVE-2026-41679	An authorization bypass and remote code execution vulnerability in Paperclip	4/21/2026	10.0

Remediation

- Upgrade Software Version: Update Paperclip deployments to version v2026.416.0 or higher, which includes the import-authorization access controls and private-hostname validation guards.
- Enforce Access Requirements: The update requires instance-administrator permissions for importing configurations into a new company and standard company-level access for importing into an existing company, applying checks to both preview and execution routes.
- Review Deployment Exposure and Registration: Re-evaluate public network accessibility and registration settings, as open registration configurations previously allowed unauthorized users to elevate import operations.